

Shadow AI Tracker

An agentic AI system that finds the AI tools your employees are already using — and tells you which ones are dangerous.

THE IDEA IN THREE SENTENCES

Employees everywhere are pasting company data into ChatGPT and dozens of other AI tools. Nobody approved it, nobody recorded it, and **no company has a list of which tools are being used**. This project builds a web application where AI agents find those tools by themselves, read each vendor's privacy policy, score the risk, and keep watching for changes every month.

SUBMITTED BY

Manishkumar Yadav

Enrolment No. **250104002031**

MBA — Cyber Security
Management, Semester III

PURPOSE OF THIS DOCUMENT

To present the proposed minor project topic to the faculty guide for discussion and approval — what it is, what problem it solves, and how it will be built.

⚠ WHY THIS TOPIC

Shadow AI is a governance problem that has appeared faster than any tool to manage it.

Firewalls, antivirus and phishing are well-studied subjects. Unsanctioned AI usage is barely two years old, has almost no tooling for mid-sized companies, and sits at the exact point where **management, law and technology meet** — which makes it a natural fit for an MBA in Cyber Security Management.

AT A GLANCE

Deliverable	Web application + report
AI approach	5 autonomous agents
Duration	14 weeks
Primary research	Practitioner survey
Live systems touched	None

THE FIVE AGENTS INSIDE THE SYSTEM

🔍 1 · Discovery

Reads the logs and finds which AI tools are in use — including ones nobody has heard of.

📄 2 · Investigator

Reads each vendor's privacy policy and terms, and quotes the clause for every answer.

🛡 3 · Challenger

Tries to disprove the Investigator. Marks anything unproven as **Not Verified**.

📊 4 · Risk & Policy

Rates every tool Red, Amber or Green and drafts the company's AI usage policy.

🔄 5 · Watcher

Re-reads every policy monthly and raises an alert the moment the wording changes.

The problem in one line: organisations cannot govern AI usage they cannot see — and today, none of them can see it.

8
questions
per tool

5
screens in
the app

1
scan every
month

01

What is “Shadow AI”?

A new risk that every company already has, and almost none can see

Shadow AI means employees using artificial-intelligence tools for work without the company knowing or approving it.

It is important to understand that this is **not sabotage and not carelessness**. Staff use these tools because the tools genuinely help. A four-hour task becomes a four-minute task. From the employee's point of view they are being efficient.

The problem appears at the company level. Every time an employee pastes something into an AI tool, that information leaves the organisation and lands on a server belonging to another company, in another country, under terms nobody in the organisation has read. And there is no record that it happened.

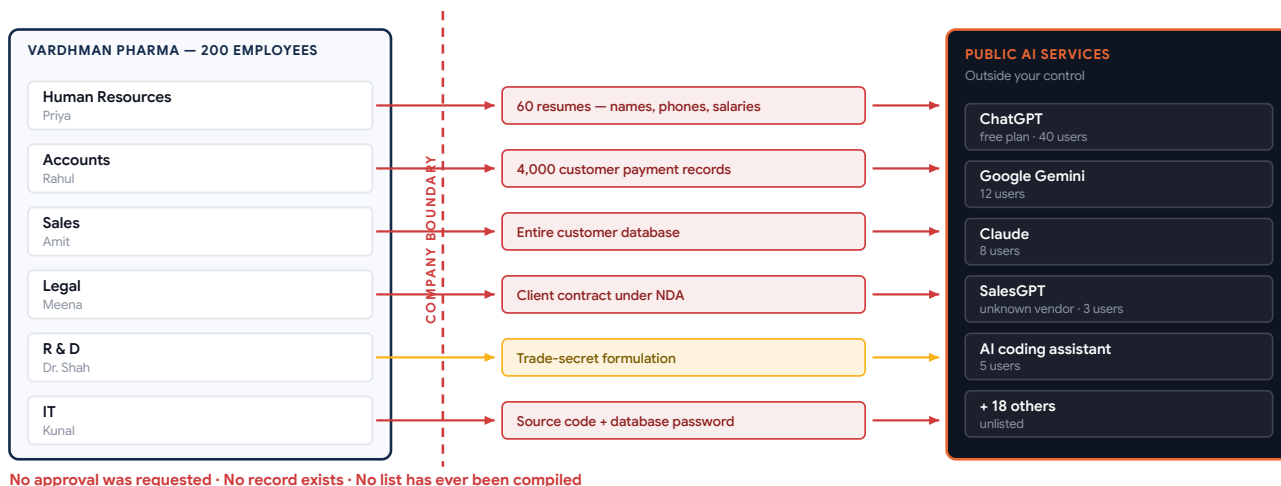
THE CORE ISSUE

You cannot govern what you cannot see.

Security teams keep an inventory of laptops, servers and software licences. Almost none keep an inventory of AI tools. The first job of this project is simply to **produce that list**.

How data leaves an organisation through Shadow AI

Illustrative view of a mid-sized company. Every arrow is a real pattern of usage; none of it is logged anywhere.



It is everywhere

Adoption reached hundreds of millions of users within two years, bottom-up — employee by employee, never through IT procurement.



It is invisible

Using a website is not an installation — no software to detect, no licence to audit, no purchase order. A browser tab leaves almost no trace.



It changes silently

Vendors revise privacy terms often and without notice. A tool that was safe in January can be risky in March, and nobody is told.

THREE QUESTIONS A COMPANY SHOULD BE ABLE TO ANSWER TODAY — AND USUALLY CANNOT

“Which AI tools does our staff use?”

Requires an inventory. Almost nobody has one — these tools were never purchased, licensed or installed.

Answer today: a guess.

“What data has been sent to them?”

Requires knowing what each department submits, not merely which tools they open.

Answer today: no record exists.

“What may those vendors do with it?”

Requires someone to have read each vendor's terms — and read them again after they changed.

Answer today: nobody has read them.

02

One week inside one company

Six ordinary employees, six ordinary decisions, six data losses nobody records

ILLUSTRATIVE CASE

Vardhman Pharma Pvt Ltd, Ahmedabad

200 employees
0 AI policies
6 leaks this week

200 employees. Manufactures generic medicines. Sells in India and exports to Germany. No AI policy exists. The subject has never been discussed internally.

A representative composite, not a real company. Each incident below reflects a documented pattern of workplace AI use.

WHO	WHAT THEY DID — AND WHY IT MADE SENSE TO THEM	WHAT ACTUALLY LEFT THE COMPANY	RISK
Priya Human Resources	Received 60 job applications for one vacancy. Uploaded all 60 resumes to ChatGPT and asked it to rank the candidates by experience. Saved four hours of work.	Names, phone numbers, home addresses, salary history and identity details of 60 individuals — none of whom consented to this.	CRITICAL Personal data
Rahul Accounts	An Excel formula would not work. Copied the whole sheet into an AI tool and asked it to fix the formula. It worked in seconds.	Payment history and contact details for 4,000 customers .	CRITICAL Customer data
Amit Sales	Found a tool called “SalesGPT” through a Google search. Uploaded the customer list so it could draft follow-up emails automatically.	The entire customer database — sent to an unknown two-person company whose terms permit them to use uploaded data freely.	CRITICAL Unknown vendor
Meena Legal	A 40-page contract arrived from the German buyer. Pasted it into an AI tool to get a quick summary before the meeting.	A confidential client contract — which itself contains a clause prohibiting disclosure to any third party. The act of summarising it breached it.	CRITICAL Contract breach
Dr. Shah R&D	Pasted a formulation process into an AI tool to help write up the documentation more clearly.	A trade secret . Legal protection for trade secrets depends on the owner taking reasonable steps to keep them secret.	HIGH IP exposure
Kunal IT	Pasted a block of code into an AI coding assistant to help find a bug. Standard practice among developers.	Source code containing a live database password in plain text.	CRITICAL Credentials

✓ What is notable about this list

Not one of these six people did anything they believed was wrong. Nobody broke a rule, because **no rule existed**. Every one of them was trying to do their job faster. This is why the problem cannot be solved by blaming employees — it has to be solved by governance.

⚠ And nobody knows

There is no log, no ticket, no approval and no record of any of the six events above. If the Managing Director were asked tomorrow “what data of ours has gone into AI tools?”, the honest answer would be “**we have no way of knowing.**”

WHAT ALL SIX INCIDENTS HAVE IN COMMON

Good intent
Every person was trying to work faster or better. None was acting against the company.

No rule broken
There was no policy to breach. You cannot enforce a rule that was never written.

No trace left
Nothing was installed and nothing was purchased, so no existing control noticed.

Effects persist
The data stays with the vendor long after the employee has forgotten the incident.

This is why the answer is governance, not discipline. Punishing employees simply pushes the usage onto personal phones, where it becomes completely invisible. The workable response is to make usage visible, assess it, and give staff approved tools instead.

03

Three months later

How an invisible problem becomes a visible business loss

From one paste to a stalled export order

The chain of events that turns a convenience into a commercial and legal problem.

Week 1

An employee pastes company data into an AI tool to save time.

→

Week 1

The data leaves the company. Nothing is logged, nobody is told.

→

Weeks 2–11

The vendor stores it under terms nobody has read. It may be used for training.

→

Week 12

The German buyer's auditor asks: which AI tools process our data?

→

Week 12+

No answer exists. The order is held for three weeks. Recorded as "lost on fit".

The failure is never recorded as a security incident — which is exactly why it keeps happening.

Legal exposure

Under India's **Digital Personal Data Protection Act, 2023**, personal data must be processed with a lawful basis and appropriate safeguards. Priya's upload of 60 resumes was neither consented to nor recorded. For an exporter, the German buyer's own **GDPR** obligations flow down the contract as well.

Contractual exposure

Most B2B contracts contain confidentiality clauses. Pasting a client's contract into a third-party AI service is disclosure to a third party. The breach is real even though nothing was "leaked" in the conventional sense and no attacker was involved.

Commercial exposure

This is the one management notices first. A customer's auditor asks a simple question, the company cannot answer it, and an order is delayed or lost. It is never recorded internally as a security failure — it is recorded as *"lost on fit"*.

THE QUESTION THAT CANNOT BE ANSWERED

"Which AI tools process our data, where is it stored, and for how long?"

This appears in supplier security questionnaires, in ISO 27001 audits, in GDPR data-processing reviews and in customer due-diligence calls. It is a reasonable question with a short answer — **provided somebody has the list.**

Today, answering it means emailing every department head and hoping people remember. With this project, it means exporting a PDF in ten seconds.

WHY EXISTING CONTROLS MISS IT

Antivirus	Nothing was installed. There is no file to scan.
Firewall	Records that a website was visited, but cannot say what was typed into it or whether the vendor is safe.
Software audit	Finds licensed software. Free web tools never appear.
Employee training	Tells people to be careful. Produces no inventory and no evidence.
Blocking all AI	Tried by some organisations. Employees move to personal phones, and visibility becomes worse, not better.

AND A GOVERNANCE QUESTION UNDERNEATH IT — WHO OWNS THIS PROBLEM?

IT Department

Sees a policy matter, not a technical one. Nothing to patch, no software to remove.

→ passes it to Legal

Legal & Compliance

Cannot assess risk without knowing which tools are used. Needs the missing inventory.

→ passes it back to IT

Human Resources

Could issue guidance, but has no basis for deciding which tools are acceptable.

→ waits for a policy

Senior Management

Unaware there is anything to decide until a customer or regulator raises it.

→ finds out last

The organisational failure beneath the technical one

Shadow AI falls between four functions and is owned by none of them — each waiting for another to act, and for information nobody is producing. **Producing it is the first step, and it is what this project builds.**

04

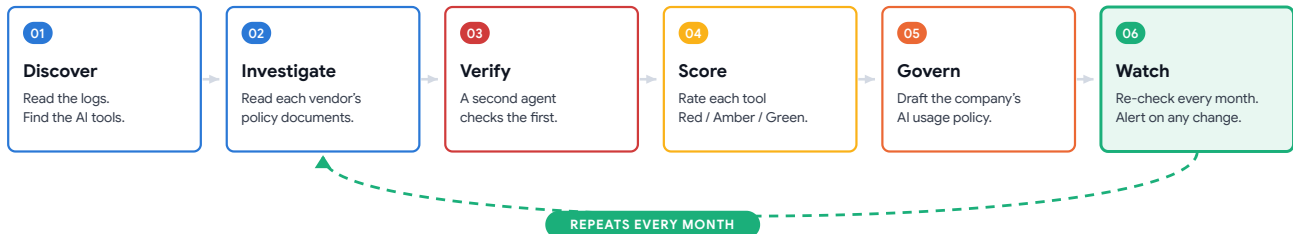
What I am building

A web application in which AI agents do the investigation work

The **Shadow AI Tracker** is a web application. An organisation connects it to its normal access logs. From that point, five AI agents work through a six-stage cycle — and repeat that cycle every month, without being asked.

The six stages

Stages 1 to 5 run on setup. Stage 6 runs on a schedule forever, and feeds its findings back into stage 2.



Stages 1–5 run once at setup. Stage 6 runs on a schedule and feeds its findings back into stage 2.

- Discover.** The agent reads the organisation's access logs and identifies which AI tools are actually in use. When it encounters an address it does not recognise, it **visits the website itself** to decide whether it is an AI service.
- Investigate.** For each tool, the agent locates and reads the vendor's privacy policy, terms of service and any published security documentation, then extracts answers to eight defined governance questions.
- Verify.** A second, independent agent attempts to disprove the first agent's answers. Any answer it cannot corroborate against a quoted clause is marked **"Not Verified"** rather than published as fact.
- Score.** Each tool receives a Red / Amber / Green rating, calculated from the vendor's terms, the sensitivity of the data being submitted to it, and the number of employees using it.
- Govern.** The application generates a draft **AI Usage Policy** for the organisation — which tools are approved, which are restricted, which are prohibited, and what staff should use instead.
- Watch.** On a monthly schedule the agent re-reads every vendor's terms, compares them against the stored version, and raises an alert if anything has changed. **This is the stage that makes the system genuinely agentic.**

WHY STAGE 6 MATTERS MOST

AI vendors revise their privacy terms often, and rarely announce it. A tool assessed as safe in one quarter can quietly become unsafe in the next. **No human being will re-read twenty-three privacy policies every month** — but an agent will do it at 3 a.m. on the first of every month, without complaint, and flag the one sentence that changed.

What the user sees:

⚠ 12 Aug – Notion AI changed its data-retention clause.
Risk moved ● Green → ● Amber.
[\[view old text\]](#) [\[view new text\]](#)

✓ What this system is

- A **visibility and governance tool** — it produces the inventory, the risk rating and the draft policy.
- A **continuous** control — it re-checks monthly instead of producing a report that ages.
- An **evidence-based** assessment — every finding cites the clause it came from.
- A **decision aid** for management, giving them something concrete to approve or reject.

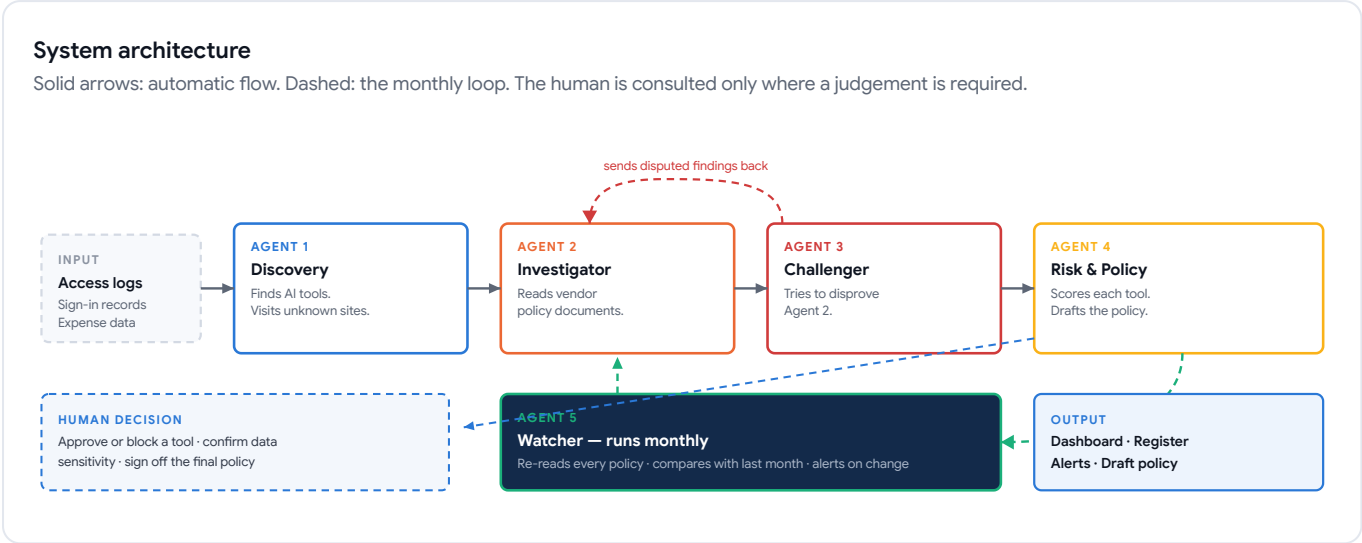
✗ What it deliberately is not

- Not a blocking tool.** It stops nobody from using anything. Blocking drives usage onto personal devices and makes the problem worse.
- Not employee surveillance.** It reports usage at department level, never individual behaviour.
- Not a data-loss prevention product.** It does not inspect the content people type.
- Not a compliance certificate.** It documents a position and identifies gaps; it declares nobody compliant.

05

The five agents

Each one has a single job, its own tools, and the ability to hand work to the next



AGENT	WHAT IT DOES	THE TOOLS IT IS GIVEN	WHAT IT PRODUCES
 1 · Discovery Agent	Reads access logs and separates AI services from ordinary websites. Where a domain is unfamiliar, it fetches the site and judges for itself.	Log parser · web fetch · domain lookup · internal tool registry	A list of AI tools in use, with user counts
 2 · Investigator Agent	Finds and reads each vendor's privacy policy, terms of service and security page — often 30 to 50 pages — and extracts answers to the eight governance questions.	Web fetch · document parser · clause extraction · citation store	Eight answers per tool, each with the exact clause quoted
 3 · Challenger Agent	Deliberately tries to disprove the Investigator. Re-reads the source and asks whether the quoted clause really supports the answer given.	Source re-fetch · claim comparison · confidence rating	Confirmed / Disputed / Not Verified for each answer
 4 · Risk & Policy Agent	Combines vendor terms, data sensitivity and user count into a single rating, then drafts the organisation's AI Usage Policy and the remediation list.	Scoring model · policy template · document generator	Red/Amber/Green rating, draft policy, action list
 5 · Watcher Agent	Runs monthly on a schedule. Re-reads every policy, compares against the stored copy, and escalates when the wording has changed.	Scheduler · stored history · text comparison · alerting	Change alerts with old and new text side by side

✓ THE DESIGN IDEA I WANT TO BE JUDGED ON

An AI system that is permitted to say “I do not know.”

Language models state wrong answers with complete confidence. If this application tells a company “*this tool does not retain your data*” and that is incorrect, the company may make a serious decision on a false statement. The Challenger Agent exists to prevent exactly that. No answer is published unless a clause can be quoted to support it.

EVERY ANSWER IS STORED AS

Question	Do they train on our data?
Answer	Yes — free plan only
Source	Privacy Policy, §4.2
Quoted text	stored verbatim
Checked on	12 Aug 2026
Status	Confirmed

06

Why this needs agents, not a chatbot

The distinction I expect to be examined on, stated plainly

OPTION A — A SIMPLE LIST

A database of known AI tools

Someone manually researches twenty popular AI tools once and stores the answers in a table.

Finds unknown tools	No
Stays current	No
Verifies itself	No

Out of date within weeks, and blind to the long tail of small tools — which is where the real risk sits.

OPTION B — A CHATBOT

Ask a language model

“What is in ChatGPT’s privacy policy?”
The model answers from memory, in one step.

Finds unknown tools	No
Stays current	No
Verifies itself	No

Answers from training data that may be a year old, with no source, no evidence and no way to tell a correct answer from an invented one.

OPTION C — THIS PROJECT

A multi-agent system

Agents go out, read the live documents, quote their sources, check each other, and come back next month.

Finds unknown tools	Yes
Stays current	Yes
Verifies itself	Yes

The work is unbounded, repetitive and never finished — which is precisely the shape of problem an agent suits and a chatbot does not.

The five properties that define an agentic system — and where each appears in this project				
Standard criteria used to distinguish an autonomous agent from a single model call.				
01 A loop Plan → act → observe → repeat, not one question and one answer. Agents 1–3 re-run until every tool has eight verified answers.	02 Tool use The agent calls real tools. It does not answer from memory. Web fetch, document parser, log reader, database, scheduler.	03 Memory It remembers previous runs and notices what has changed. Every finding is stored with its source and the date it was read.	04 Multiple roles Separate agents check and challenge each other. Agent 3 exists only to disprove Agent 2.	05 Knows when to stop It decides when the job is done or a human is needed. Unverifiable findings escalate instead of being guessed.

 IN ONE SENTENCE A chatbot answers a question. An agent is given a job and returns when it is finished. Reading twenty-three privacy policies, checking each answer against its source and repeating it monthly is a job, not a question.	 Human decision points The agents investigate and recommend. They never decide alone. Three decisions stay with a person: - Approving or blocking a tool for the organisation - Confirming how sensitive a category of data is - Signing off the final AI Usage Policy
--	--

WHAT ONE AGENT RUN ACTUALLY LOOKS LIKE — A WORKED TRACE FOR A SINGLE TOOL

STEP	AGENT	ACTION TAKEN	RESULT
1	Discovery	Notices <code>otter.ai</code> in the logs. Not in the registry, so it fetches the homepage and reads it.	Classified as an AI tool
2	Investigator	Retrieves the privacy policy, terms of service and security page.	Three documents stored
3	Investigator	Reads them and extracts the eight answers, quoting a clause for each.	7 found, 1 not located
4	Challenger	Tests all seven against the quoted text and returns the one it cannot corroborate.	6 confirmed · 1 sent back
5	Risk & Policy	Scores the tool from the confirmed findings, the data type and the user count.	Rated Amber · 2 gaps listed
6	Watcher	Stores everything with today’s date and schedules the next check one month from now.	Next run: 01 Sep 2026

Steps 3–4 form the loop; step 6 is why the system stays useful after installation day. Neither is possible with a single model call.

07

The eight questions, and how risk is scored

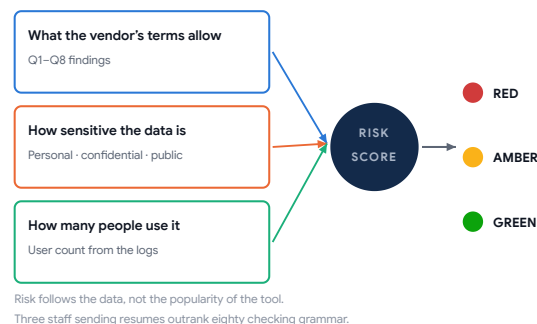
The analytical core of the project — this is my own framework, not a borrowed one

Every AI tool the system finds is assessed against the same eight questions. Designing this list is the main intellectual work of the project: it decides what the agents look for and what the risk rating means.

#	THE QUESTION ASKED OF EVERY VENDOR	WHY IT MATTERS
Q1	Do they train their AI on what we type in?	The single biggest factor. If yes, your data may influence answers given to other people.
Q2	Can training be switched off, and on which plan?	Often the paid tier behaves completely differently from the free tier.
Q3	How long is our data retained?	Determines how long the exposure lasts after the employee has forgotten about it.
Q4	In which country are the servers located?	Governs which laws apply and whether a cross-border transfer has occurred.
Q5	Will they sign a data processing agreement?	Usually required before the tool can lawfully handle personal data at all.
Q6	Do they hold a recognised security certification?	ISO 27001 or SOC 2 indicates the vendor has been independently examined.
Q7	Do they share data with other companies?	Sub-processors extend the exposure to parties the organisation never chose.
Q8	Can we require deletion on request?	Necessary to satisfy data-principal rights under the DPDP Act and GDPR.

How the rating is calculated

Three inputs, one output.



⚠ Deliberate design choice

A tool used by **three** people to handle resumes is rated more dangerous than a tool used by **eighty** people to correct marketing grammar. Risk follows the **data**, not the popularity.

Worked example — the same four tools, rated

TOOL	USERS	DATA BEING SUBMITTED	KEY FINDING FROM THE VENDOR'S OWN TERMS	RATING
ChatGPT (free plan)	40 staff	Resumes, customer payment sheets	On the free tier, submitted content may be used to improve the service. No data processing agreement is available at this tier.	RED
SalesGPT (unknown vendor)	3 staff	Complete customer database	No privacy policy could be located. Company registration and server location could not be established.	RED
Grammarly	12 staff	Marketing copy only	Business tier available with defined retention. No personal or confidential data currently being submitted.	AMBER
Microsoft Copilot (business tier)	25 staff	Internal documents	Enterprise agreement signed, training on tenant data disabled, retention and region contractually defined.	GREEN

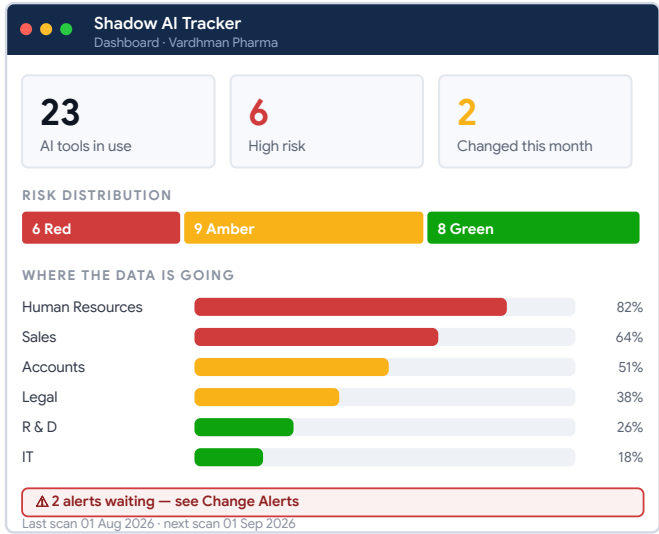
Vendor terms shown here are illustrative examples for the purpose of explaining the model. In the working application every one of these findings is fetched live from the vendor's published documents at the time of assessment and stored with the quoted clause and the date it was read — precisely because such terms change.

08

What the application looks like

Five screens — the planned interface of the working prototype

SCREEN 1 · DASHBOARD



The first thing a security manager sees: the total inventory, the risk split, and anything that changed since last month.

SCREEN 2 · TOOL REGISTER

Tool Register

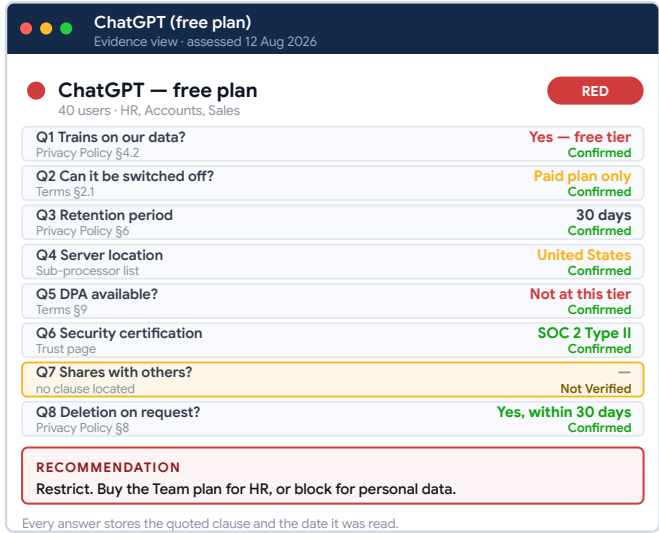
23 AI tools discovered

TOOL	USERS	DATA SUBMITTED	RISK
● ChatGPT free plan	40	Resumes, payments	RED
● salesgpt.io unknown vendor	3	Customer database	RED
● AI coding assistant	5	Source code	RED
● QuillBot	4	Client documents	RED
● DeepL free tier	9	Contracts	RED
● Perplexity	6	Research notes	RED
● Google Gemini	12	Contracts, email	AMBER
● Grammarly	12	Marketing copy	AMBER
● Otter.ai	7	Meeting audio	AMBER
● Canva AI	14	Brand assets	AMBER
● Microsoft Copilot business tier	25	Internal documents	GREEN
● GitHub Copilot business tier	5	Source code	GREEN

Sorted by risk · 12 more below · export as CSV or PDF

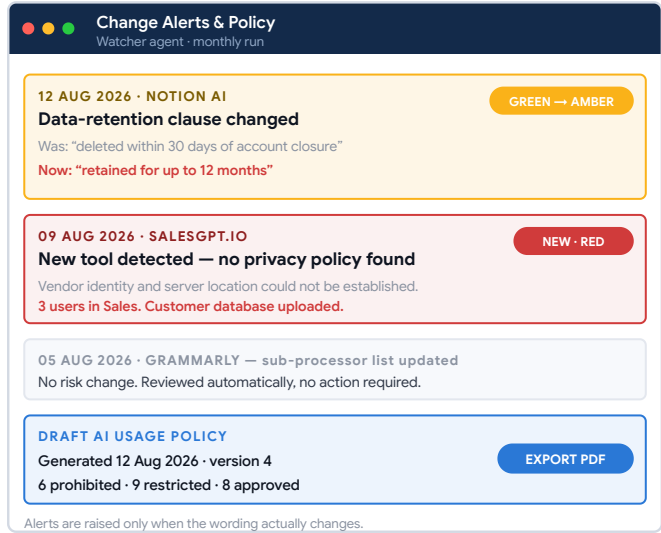
Every AI tool discovered, sorted by risk, showing who uses it and what kind of data is going into it.

SCREEN 3 · TOOL DETAIL — THE EVIDENCE VIEW



The eight answers, each with the clause the agent quoted and the date it was read. Anything unproven is shown as Not Verified, never guessed.

SCREEN 4 · CHANGE ALERTS · SCREEN 5 · POLICY



The Watcher Agent's output, and the auto-drafted AI Usage Policy that the organisation can review, edit and adopt.

HOW A SECURITY MANAGER ACTUALLY USES IT — ONE MONTH IN FIVE STEPS

1st of the month

The Watcher Agent runs overnight without being asked. Nobody has to remember anything.

Monday morning

Two alerts are waiting on the dashboard: one vendor changed its terms, one new tool appeared.

Ten minutes later

He opens the evidence view, reads the old and new clause side by side, and decides.

When the auditor asks

He exports the register as a PDF. A question that used to stall an order now takes ten seconds.

✓ Design principle behind the interface

Every screen answers one question and shows its evidence. There is no page that simply asserts a conclusion — a user can always click through to the clause the agent quoted and the date it was read.

👤 Who each screen is for

Screens 1 and 4 are for management. Screens 2 and 3 are for whoever does the assessment work. Screen 5 is what leaves the building — to an auditor, a customer or the board.

09

How I will carry out the project

Research first, build second, validate third

PHASE 1 · RESEARCH

Establish that the problem is real

Rather than relying only on published literature, I will collect **primary data** through an anonymous survey of working professionals.

Target sample40–60 respondents

MethodAnonymous online form

Duration2 weeks

Questions cover: which AI tools they use at work, whether their employer has given permission, whether an AI policy exists, and whether they have ever submitted company data to such a tool.

PHASE 2 · BUILD

Construct the working prototype

Built incrementally, one agent at a time, with each agent tested in isolation before being connected to the next.

ApproachAI-assisted development

OrderAgent 1 → 5, then UI

Duration7 weeks

Code is generated with an AI coding assistant under my direction. The architecture, the eight questions, the scoring model and all design decisions are mine, and I will be able to explain every component.

PHASE 3 · VALIDATE

Test whether it actually works

The agents' findings are compared against a manual reading of the same documents, done by me, to measure accuracy.

Tools assessed20–25

Accuracy measureAgent vs. manual

Duration3 weeks

I will also present the prototype to two or three working security or compliance practitioners for structured feedback on usefulness.

DATA USED IN THE PROJECT

DATA	SOURCE	NOTE
Organisational access logs	Synthetic	Generated by me to represent a 200-person company. The generation method is documented in the report. No real organisation's logs are used.
Vendor policy documents	Real, public	Privacy policies and terms of service that AI vendors publish openly on their own websites.
Survey responses	Real, anonymous	Collected with informed consent. No names, employers or identifying details recorded.
Practitioner feedback	Real, consented	Structured interviews on the prototype's usefulness.

🔒 Boundaries I will observe

- No real organisation's network, systems or logs will be accessed.
- No scanning, probing or testing of any third-party infrastructure. The agents read **published documents only**.
- Survey participation is voluntary and anonymous.
- The application reports a documented position and gaps. It **does not certify legal compliance**, and the interface will state this clearly.

📊 How accuracy will be measured

For 20 tools × 8 questions = **160 findings**, I will independently read the same source documents and record the correct answer. Agreement rate, false-confidence rate and the proportion correctly marked “Not Verified” become the quantitative results of the project.

10

Technology and schedule

Deliberately simple tools, and a fourteen-week plan

TECHNOLOGY STACK

LAYER	CHOICE	REASON
Web application	Next.js (React)	Single framework for both the interface and the server logic. Widely documented.
Database	SQLite	A single file. No installation, no server, nothing to configure or break during a demonstration.
AI agents	Claude API	Supports the tool-use and multi-step reasoning the agent design requires.
Document reading	Web fetch + parser	Retrieves and cleans vendor policy pages for the Investigator Agent.
Scheduling	Cron job	Triggers the Watcher Agent monthly.
Charts	Recharts	Dashboard visualisations.

EFFORT ESTIMATE

Research & survey	2 weeks
Design & framework	2 weeks
Build	7 weeks
Validation	2 weeks
Report & presentation	1 week
Total	14 weeks

✓ Feasibility

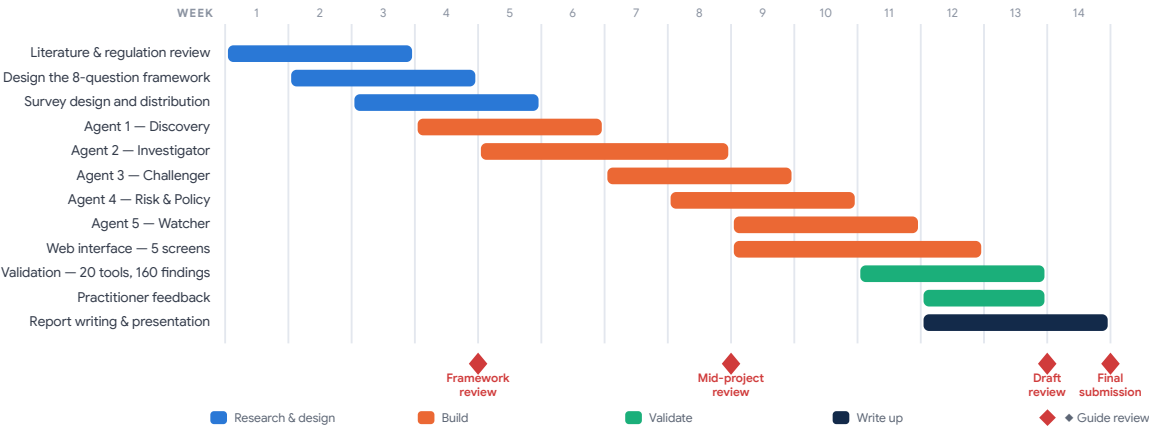
There is no machine-learning model to train, no dataset to label, no infrastructure to provision and no hardware requirement. The project runs on a laptop. The risk of not finishing is therefore low, and the scope can be reduced by dropping Agent 5 (the Watcher) if time runs short — although that is the component I most want to keep.

<> On AI-assisted development

The application code will be written with the help of an AI coding assistant. I consider this appropriate to declare openly rather than conceal: it is now standard professional practice, and it is what allows a management student to deliver a working system rather than only a proposal. The design decisions, the eight-question framework, the scoring model, the validation and the analysis are entirely my own work, and I will be able to explain and defend every part of the system.

Fourteen-week schedule

Bars show planned working weeks. Diamonds mark review points with the faculty guide.



RISKS TO COMPLETING THE PROJECT, AND HOW EACH IS MANAGED

RISK	LIKELIHOOD	MITIGATION
Vendor websites block automated retrieval	MEDIUM	Download the document manually; the agent still performs the reading and extraction. The contribution is unaffected.
Agents extract answers inaccurately	MEDIUM	A measured result rather than a failure — accuracy is one of the findings, and the Challenger Agent exists to bound it.
Survey response rate is low	MEDIUM	Distribute through several channels and extend by a week. Forty responses is the minimum reporting threshold.
The build runs beyond seven weeks	LOW	Agent 5 is the designated cut. The remaining four still form a complete, demonstrable system.

11

Outcomes, relevance and evaluation

What will be delivered, why it matters academically, and how success is judged

DELIVERABLES



1 · Working web application

Five agents, five screens, running end to end on a laptop and demonstrable live.



2 · Project report

Literature, survey findings, framework design, implementation, validation results, conclusions.



3 · Survey findings

Original primary data on unsanctioned AI usage among working professionals in India.



4 · Assessment framework

The eight-question model and scoring method, usable independently of the software.

 **REGULATORY RELEVANCE**

The project connects directly to three bodies of law now affecting Indian organisations:

India	DPDP Act, 2023
Europe	GDPR
Europe	EU AI Act
Standards	ISO/IEC 42001 · 27001

Each requires an organisation to know what it processes, where and by whom. An inventory of AI tools is a precondition for all of them — which is what makes an inventory a governance instrument and not merely a list.

EVALUATION CRITERIA — HOW I PROPOSE SUCCESS BE JUDGED

CRITERION	TARGET
Agents correctly identify AI tools from logs, including tools not on any pre-existing list	≥ 90% correctly classified
Extracted answers agree with my own manual reading of the same documents	≥ 85% agreement
Confidently stated but incorrect answers (the failure mode that matters most)	< 5% of findings
Watcher Agent detects a genuine change in vendor terms between two runs	Demonstrated live
Survey sample collected	≥ 40 valid responses

 **Why this suits an MBA in Cyber Security Management**

- The central problem is **governance**, not engineering — visibility, policy and accountability.
- It requires understanding **law and business risk**, not just technology.
- It produces a **management artefact**: an inventory, a risk rating and a signed policy.
- It applies **research method**: primary survey, framework design, measured validation.
- It engages an **emerging technology** from the position of the person who has to govern it.

LIMITATIONS I ACKNOWLEDGE IN ADVANCE

- The prototype uses **synthetic log data**. Deployment in a real organisation is out of scope for a minor project.
- The agents read **published policies only**. What a vendor actually does internally cannot be verified from outside.
- The tool **does not certify compliance**. It documents a position and identifies gaps.
- Findings are accurate **as at the date read**, which is exactly why the Watcher Agent exists.

GUIDANCE I WOULD VALUE

- Whether the eight-question framework is the right depth, or should be expanded.
- Whether the survey sample of 40–60 is adequate for the report's requirements.
- Whether the scope should be reduced to four agents to reduce delivery risk.

12

Summary

The proposal in one page

THE PROPOSAL

Build a web application in which five AI agents discover the AI tools an organisation is unknowingly using, read each vendor's terms, verify each other's findings, rate the risk, draft the governing policy — and keep checking every month.

The problem is current, largely untooled, and sits precisely where management, law and technology meet.

Student	Manishkumar Yadav
Enrolment	250104002031
Programme	MBA — CSM, Sem III
Duration	14 weeks
Deliverables	4

THE PROBLEM

No list

Organisations have no inventory of the AI tools their staff use, so they cannot govern them.

THE SOLUTION

5 agents

Autonomous agents that discover, investigate, verify, score and monitor — on a repeating cycle.

THE CONTRIBUTION

Evidence

Every finding must cite a clause. Anything unproven is marked “Not Verified”, never guessed.

THE PROOF

Live demo

An agent that detects a real change in a vendor’s terms between two runs, unprompted.

INDICATIVE READING AND REFERENCE BASE

To be expanded and formatted to the required citation style in the final report.

- 1
- The Digital Personal Data Protection Act, 2023 (India), and the Rules framed thereunder.
- 2
- Regulation (EU) 2016/679 — General Data Protection Regulation, in particular Articles 5, 28 and 32.
- 3
- Regulation (EU) 2024/1689 — the Artificial Intelligence Act, transparency and governance provisions.
- 4
- ISO/IEC 42001:2023 — Artificial Intelligence Management System requirements.
- 5
- ISO/IEC 27001:2022 — Annex A controls on asset inventory and supplier relationships.
- 6
- NIST AI Risk Management Framework (AI RMF 1.0), 2023.
- 7
- CERT-In Directions on information security practices, April 2022.
- 8
- Published privacy policies and terms of service of the assessed AI vendors (primary sources, accessed with dates recorded).
- 9
- Literature on Shadow IT governance, as the closest established analogue to Shadow AI.
- 10
- Current industry surveys on generative AI adoption and data-handling incidents in the workplace.

REQUEST

I am seeking approval to proceed with this topic, and would welcome guidance on the three questions raised on the previous page — particularly on whether to keep all five agents or reduce the scope to four.

Manishkumar Yadav

Enrolment No. 250104002031

MBA (Cyber Security Management), Semester III

School of Management Studies

National Forensic Sciences University, Gandhinagar

Signature of Student

Signature of Project Guide